

Red vs Blue Windows IR / Containment Cheat Sheet

v0.5 (PowerShell Only)

Kill Suspicious Process

- By PID: `Stop-Process -Id <PID> -Force`
- By name: `Stop-Process -Name <ProcessName> -Force`
- Verify PID gone: `Get-Process -Id <PID> -ErrorAction SilentlyContinue`
- Verify name gone: `Get-Process -Name <ProcessName> -ErrorAction SilentlyContinue`

Audit Processes + Persistence

- Top CPU: `Get-Process | Sort CPU -Desc | Select -First 20 Id,ProcessName,CPU`
- Process owners: `Get-Process -IncludeUserName | Select Id,ProcessName,UserName`
- Parent/child view: `Get-CimInstance Win32_Process | Select ProcessId,ParentProcessId,Name`
- Startup entries: `Get-CimInstance Win32_StartupCommand | Select Name,Command,Location,User`
- Scheduled tasks: `Get-ScheduledTask | ? State -ne 'Disabled' | Select TaskName,TaskPath,State`

Service Containment + Verification

- List running services: `Get-Service | ? Status -eq 'Running' | Select Name,DisplayName,Status`
- Query by name: `Get-Service -Name <ServiceName> -ErrorAction Stop`
- Wildcard search: `Get-Service -Name '*<Keyword>*'`
- Stop service now: `Stop-Service -Name <ServiceName> -Force -NoWait -PassThru`
- Restart service: `Restart-Service -Name <ServiceName> -Force -PassThru`
- Start service: `Start-Service -Name <ServiceName>`
- Disable at boot: `Set-Service -Name <ServiceName> -StartupType Disabled`
- Set manual start: `Set-Service -Name <ServiceName> -StartupType Manual`
- Full service details: `Get-CimInstance Win32_Service -Filter "Name='<ServiceName>'" | Select Name,State,StartMode`
- Dependency checks: `Get-Service -Name <ServiceName> -DependentServices / Get-Service -Name <ServiceName> -RequiredServices`

Fast Host Isolation

- Block inbound: `Set-NetFirewallProfile -Profile Domain,Public,Private -DefaultInboundAction Block`
- Block outbound: `Set-NetFirewallProfile -Profile Domain,Public,Private -DefaultOutboundAction Block`
- Add block rule (example): `New-NetFirewallRule -DisplayName 'IR Block C2 203.0.113.10' -Direction Outbound -Act...`
- Verify/rollback rule: `Get-NetFirewallRule -DisplayName 'IR Block C2 203.0.113.10' / Remove-NetFirewallRule -DisplayName 'IR Block C2 203.0.113.10'`
- Disable active NICs: `Get-NetAdapter | ? Status -eq 'Up' | Disable-NetAdapter -Confirm:$false`

Containment Rollback (Re-Enable)

- Re-enable DNS recursion: `Set-DnsServerRecursion -Enable $true`
- Verify recursion state: `Get-DnsServerRecursion | Select Enable`
- Re-enable/clear machine PS lockdown override: `[System.Environment]::SetEnvironmentVariable("__PSLockdownPolicy",`

Current Ports In Use

- TCP: `Get-NetTCPConnection | Select LocalAddress,LocalPort,State,OwningProcess`
- UDP: `Get-NetUDPEndpoint | Select LocalAddress,LocalPort,OwningProcess`
- Established: `Get-NetTCPConnection -State Established | Select LocalPort,RemotePort,OwningProcess`
- PID → Service: `Get-CimInstance Win32_Service | ? ProcessId -eq <PID> | Select Name,State`
- PID → Process: `Get-Process -Id <PID>`

AD Users (Create / Remove / Query)

- Module: `Import-Module ActiveDirectory`
- List users: `Get-ADUser -Filter * | Select Name,SamAccountName`
- Query user: `Get-ADUser -Identity <SamAccountName> -Properties *`
- Create user: `New-ADUser -Name <Name> -SamAccountName <SamAccountName>`
- Remove user: `Remove-ADUser -Identity <SamAccountName> -Confirm:$false`

User Changes (net user / net localgroup)

- List local users: `net user`
- Show user details: `net user <username>`
- Change password: `net user <username> *`
- Disable / enable user: `net user <username> /active:no / net user <username> /active:yes`
- Add / remove local user: `net user <username> <Password> /add / net user <username> /delete`
- Add / remove local admin: `net localgroup Administrators <username> /add / net localgroup Administrators <username> /delete`
- Domain account change (from domain-joined host): `net user <username> * /domain`

Event Viewer Flow (LDAP / AD Services)

1. Open Event Viewer: `eventvwr.msc`
2. Review these logs: Windows Logs > Security ; Applications and Services Logs > Directory Service ; Applications and Services Logs > Active Directory Web Services
3. In each log, click *Filter Current Log...*; set *Logged* to last 1–4 hours and use Event IDs from the table below.
4. Sort by *Date and Time* (newest first), then inspect suspicious events for account, source host/IP, service, and object DN.
5. Pivot with *Find...* using username/computer/IP/service account to connect activity across logs.
6. Preserve evidence: *Save Filtered Log File As .evtx* and export/copy details into case notes.

Important Event IDs (LDAP / AD Services)

Event ID	Log	What it tells you
2886	Directory Service	Domain controller is not enforcing LDAP signing policy (hardening gap).
2887	Directory Service	Count of LDAP simple binds / unsigned binds in interval.
2888	Directory Service	Unsigned/simple LDAP binds were rejected (policy enforcement impact).
2889	Directory Service	Client details for insecure LDAP bind attempts (source tracing).
4624	Security	Successful logon (track account, logon type, source workstation/IP).
4625	Security	Failed logon attempt (password spray/brute force signal).
4768	Security	Kerberos TGT request (initial Kerberos auth activity).
4769	Security	Kerberos service ticket request (service access patterning).
4771	Security	Kerberos pre-authentication failed (bad creds/time skew/attack).
4776	Security	NTLM authentication validation (legacy auth and DC validation events).
4740	Security	Account lockout triggered.
4728 / 4732 / 4756	Security	Member added to privileged group (global / local / universal).
4729 / 4733 / 4757	Security	Member removed from group (check for cleanup or tampering).
5136 / 5137 / 5139 / 5141	Security	AD object modified / created / moved / deleted.

Hunt Recent EXE Files (PowerShell)

- Set scope: `$r=$env:USERPROFILE`
- Cache EXE list: `$e=Get-ChildItem $r -Recurse -Force -Filter *.exe -EA 0`
- EXE + full path: `$e | Select Name,FullName`
- EXE created (1d): `$e | ? CreationTime -gt (Get-Date).AddDays(-1) | Select FullName,CreationTime`
- EXE modified (1d): `$e | ? LastWriteTime -gt (Get-Date).AddDays(-1) | Select FullName,LastWriteTime`
- Modified (10d): `$e | ? LastWriteTime -gt (Get-Date).AddDays(-10) | Select FullName,LastWriteTime`
- EXE smaller than 6MB: `$e | ? Length -lt 6MB | Select FullName,Length`

Microsoft Security Compliance Toolkit (SCT) Flows

1. Baseline compare (Policy Analyzer): Download SCT from Microsoft Download Center (ID 55319), extract `PolicyAnalyzer.zip`, load Microsoft baseline `*.PolicyRules` files plus your environment rules, then export differences to CSV for triage/change control.
2. Safe local apply (LGPO): Backup first with `.\LGPO.exe /b C:\IR\LGPO-PreSCT`, then import baseline backup(s) with `.\LGPO.exe /g "<BaselineGpoBackupRoot>"`.
3. Validate + enforce: `gpupdate /force; gpresult /h C:\IR\gpresult_sct.html`; spot-check critical settings/events before broad rollout.
4. Rollback flow: Re-import your backup with `.\LGPO.exe /g C:\IR\LGPO-PreSCT` and rerun `gpupdate /force` to return to pre-change local policy state.

Sysinternals Quick Checks

- Check who can control SCM: `accesschk64.exe -uwcqv "Authenticated Users" scmanager`
- Check who can control service: `accesschk64.exe -ucqv Spooler`
- Check write access to folder: `accesschk64.exe -uwd "Domain Users" C:\Program Files\`
- Check registry permissions: `accesschk64.exe -uvw "Users" HKLM\Software`
- Find services writable by non-admins: `accesschk64.exe -uwcqv "Users" *`
- Check signature and publisher: `sigcheck64.exe C:\Windows\System32\svchost.exe`
- Search strings for HTTP indicators: `strings64.exe suspicious.exe | findstr http`

Sysinternals Threat-Hunt + Cleanup Playbooks

1. **Autoruns64.exe** - Hunt: run `.\tools\sysinternals\Autoruns 64.exe`, enable *Options > Hide Microsoft Entries*, then review *Logon, Services, Scheduled Tasks*, and *WMI* for unknown, unsigned, or non-essential startup entries. Cleanup: uncheck first to disable, reboot and validate business impact, then delete confirmed malicious entries and remove backing files/tasks/services.
2. **procexp64.exe (Process Explorer)** - Hunt: run `.\tools\sysinternals\procexp 64.exe`, sort by signer/company, inspect abnormal parent-child chains, and verify suspicious binaries with *Check VirusTotal.com*. Cleanup: kill confirmed malicious process trees, then remove persistence (service/task/run key) tied to those PIDs.
3. **Procmon64.exe (Process Monitor)** - Hunt: run `.\tools\sysinternals\Procmon 64.exe` with filters for *RegSetValue, CreateFile*, and *Process Create* touching startup paths, task cache, services, WMI repo, and user temp directories. Cleanup: identify exact file/registry artifacts from events and delete/disable them in place.
4. **tcpview64.exe** - Hunt: run `.\tools\sysinternals\tcpview 64.exe`, focus on unexpected established outbound sessions and frequent reconnect behavior to rare remote IPs/ports. Cleanup: terminate owning process from TCPView, then block destination IP/domain via firewall and remove related persistence.
5. **sigcheck64.exe** - Hunt: run `.\tools\sysinternals\sigcheck 64.exe -u -e -vt C:\Windows\System 32` and targeted scans on user-writable paths to find unsigned or reputation-poor binaries. Cleanup: quarantine/delete flagged binaries after path/process validation, then re-run sigcheck to confirm no remaining unsigned implants in scope.
6. **strings64.exe** - Hunt: run `.\tools\sysinternals\strings 64.exe <suspect.exe> | findstr /i "http https cmd powershell rundll regsvr mshta pastebin token key"` to surface C2, LOLBIN, and credential artifacts. Cleanup: use extracted IOCs (domains, mutexes, paths) to block, search, and eradicate related components.
7. **streams64.exe** - Hunt: run `.\tools\sysinternals\streams 64.exe -s C:\Users` (and other writable roots) to detect alternate data streams used for hidden payloads. Cleanup: remove malicious ADS with `streams64.exe -d <path>` and confirm parent file legitimacy before deleting host files.
8. **accesschk64.exe** - Hunt: run `.\tools\sysinternals\accesschk 64.exe -uwcqv "Users" *` and targeted checks on services/registry/program directories to find writable privilege-escalation paths. Cleanup: tighten ACLs (remove broad write permissions), then retest with accesschk to verify exposure is closed.
9. **PsExec64.exe** - Hunt: review Security/System events for remote service execution artifacts (`psexesvc`), and correlate with unexpected admin logons and lateral movement timing. Cleanup: stop/delete rogue remote services, rotate compromised credentials, and restrict remote admin pathways (SMB/admin shares/firewall).
10. **ADExplorer.exe** - Hunt: run `.\tools\sysinternals\ADExplorer .exe` and inspect snapshots for newly privileged users/groups, suspicious delegation/SPN changes, and rogue GPO-linked objects. Cleanup: remove unauthorized group memberships/objects, revert malicious attribute changes, and force AD replication checks.
11. **dnsutil.exe** - Hunt: run `.\tools\sysinternals\dnsutil .exe -t 15` to monitor DNS health and identify repeated failure/abuse conditions during containment. Cleanup: restart affected DNS services, clear poisoned resolver states, and restore known-good server/forwarder settings.
12. **Sysmon64.exe + sysmonconfig.xml** - Hunt: verify sensor status with `.\tools\sysinternals\Sysmon 64.exe -c` and query high-signal events (process create, network connect, image load, WMI, task/service creation) in Event Viewer/SIEM. Cleanup: update config with `.\tools\sysinternals\Sysmon 64.exe -c .\tools\sysinternals\sysmonconfig.xml`, then tune include/exclude rules to reduce noise while preserving malicious behavior visibility.

Fix DNS (Sysinternals DNSUtil)

- Verify DNS-related services: `Get-Service DNS,Dnscache -ErrorAction SilentlyContinue | Select Name,Status,StartType`
- Run DNSUtil watchdog (15s polling): `.\tools\sysinternals\dnsutil .exe -t 15`
- Restart DNS service once (DNS server role): `Restart-Service DNS -Force`
- Flush resolver cache (client): `Clear-DnsClientCache / ipconfig /flushdns`
- Reset NIC DNS to DHCP: `Set-DnsClientServerAddress -InterfaceAlias "<NIC>" -ResetServerAddresses`
- Set known-good DNS servers: `Set-DnsClientServerAddress -InterfaceAlias "<NIC>" -ServerAddresses ("1.1.1.1","8.8.8.8")`
- Validate resolution: `Resolve-DnsName microsoft.com / nslookup microsoft.com`

Seatbelt Threat Hunting Queries

- Persistence mechanisms: `Seatbelt.exe AutoRuns ScheduledTasks Services WMIEventConsumer WMIEventFilter WMIFilterBinding`
- Credential exposure: `Seatbelt.exe CloudCredentials WindowsVault CredEnum WindowsCredentialFiles DpapiMasterKeys WindowsAutoLogon KeePass PuttySessions`
- Lateral movement indicators: `Seatbelt.exe RDPSSessions RDPSavedConnections LogonEvents ExplicitLogonEvents NetworkShares MappedDrives`
- Defense evasion awareness: `Seatbelt.exe WindowsDefender AMSIProviders AppLocker Sysmon PowerShell UAC CredGuard WindowsFirewall`
- Suspicious process/network activity: `Seatbelt.exe InterestingProcesses Processes TcpConnections UdpConnections NamedPipes`
- Event log mining: `Seatbelt.exe PowerShellEvents SysmonEvents ProcessCreationEvents "LogonEvents 30" "ExplicitLogonEvents 30"`
- LOLBAS coverage: `Seatbelt.exe LOLBAS`
- Quick full triage: `Seatbelt.exe -group=all -full -outputfile="C:\Temp \trriage .json"`
- Suggested workflow: run targeted queries first, then run full triage JSON collection for deeper offline analysis or SIEM ingestion.